

REPORT DI SECURITY ASSESSMENT – BANANA INC.

Cliente: Banana Inc.

Società di consulenza: NemiSec

Analyst: Emy Mangogna

Table of Contents

Executive Summary.....	p.2
Descrizione dell’architettura e criticità individuate.....	p.2
Analisi delle vulnerabilità e raccomandazioni.....	p.3
• Vulnerabilità applicative (SQL Injection e XSS). • Impatto economico di un attacco DdoS • Gestione di un’infezione malware sulla Web App	
Soluzione integrata.....	p.5
Conclusioni.....	p.5

Executive Summary

L'azienda **Banana Inc.** ha incaricato **NemiSec** di effettuare una valutazione della sicurezza dell'infrastruttura che supporta la propria piattaforma e-commerce. L'obiettivo dell'analisi è identificare le principali vulnerabilità, quantificare l'impatto potenziale di scenari di attacco e proporre misure correttive finalizzate a ridurre il rischio operativo e la perdita economica.

Le analisi condotte evidenziano tre aree critiche:

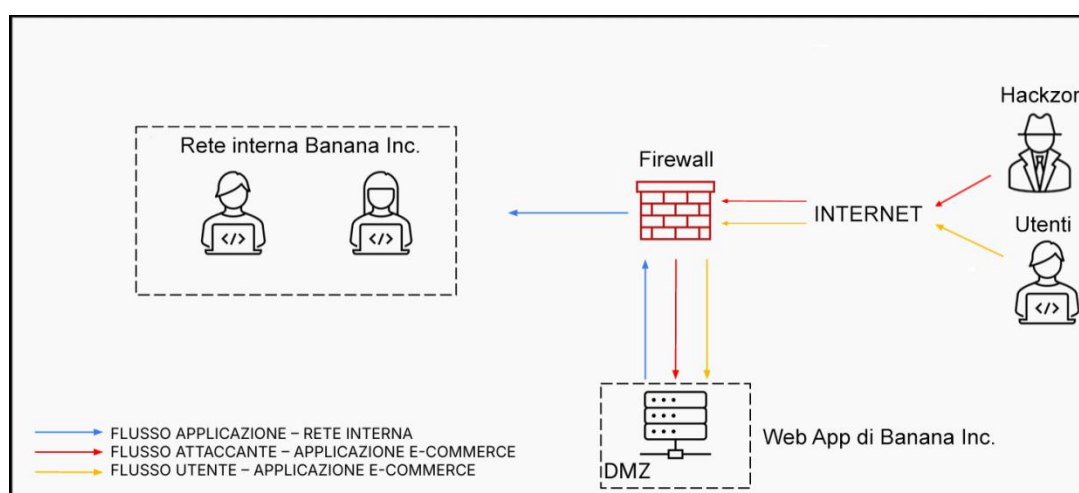
1. **Rischio di attacchi applicativi (SQL Injection e XSS)** che possono compromettere dati sensibili e integrità del sistema.
2. **Rischio di interruzione del servizio (DDoS)** con impatto economico stimato in 15.000 € per 10 minuti di indisponibilità.
3. **Rischio di infezione malware sulla Web App**, con potenziale propagazione verso la rete interna.

Per ciascuna area, **NemiSec** propone una serie di contromisure preventive e operative, con l'obiettivo di garantire continuità del servizio e contenimento degli incidenti.

Descrizione dell'architettura e criticità individuate

La web app di **Banana Inc.** è esposta su Internet e accessibile dai clienti per l'acquisto di prodotti. L'architettura attuale prevede:

- **Zona DMZ:** ospita la Web Application accessibile dall'esterno dagli utenti.
- **Rete interna:** ospita sistemi e dati aziendali non esposti direttamente a Internet.
- **Firewall:** regola il traffico tra Internet, DMZ e rete interna.



La configurazione attuale consente la comunicazione dalla DMZ verso la rete interna. Tale configurazione rappresenta una criticità: qualora un server nella DMZ venga compromesso, un attaccante potrebbe potenzialmente raggiungere la rete interna, esponendo dati sensibili e sistemi critici.

Analisi delle vulnerabilità e raccomandazioni

Vulnerabilità applicative (SQL Injection e XSS)

Descrizione del rischio:

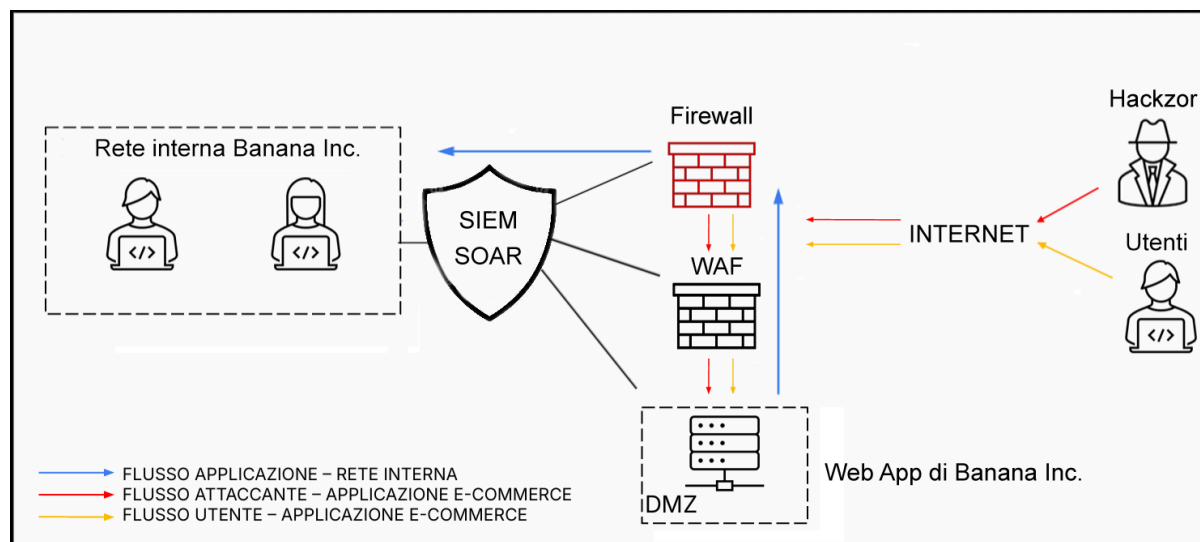
Gli attacchi di tipo SQL Injection e Cross Site Scripting (XSS) rappresentano minacce comuni per applicazioni web. In caso di successo, tali attacchi possono consentire l'accesso non autorizzato ai dati, la manipolazione di contenuti o l'esecuzione di codice malevolo.

Raccomandazione:

Si raccomanda l'implementazione di un **Web Application Firewall (WAF)** a protezione del traffico web in ingresso. Il WAF analizza e blocca automaticamente richieste sospette o malformate, riducendo significativamente il rischio di attacchi applicativi.

Integrazione consigliata:

Si suggerisce inoltre l'adozione di un sistema di monitoraggio centralizzato (**SIEM/SOAR**) per raccogliere log e alert provenienti da firewall, WAF, DMZ e rete interna, al fine di migliorare visibilità e capacità di risposta agli incidenti.



Impatto economico di un attacco DDoS

Descrizione del rischio:

Un attacco DDoS (Distributed Denial of Service) può rendere la piattaforma non raggiungibile, impedendo agli utenti di effettuare acquisti.

Scenario analizzato:

Indisponibilità del servizio per **10 minuti**.

Valore medio delle transazioni: **1.500 € per minuto**.

Stima dell'impatto economico:

1.500 € × 10 minuti = 15.000 € di fatturato potenziale non realizzato.

Raccomandazioni:

- Implementare soluzioni anti-DDoS (es. protezione dedicata o servizi CDN).
- Introdurre meccanismi di mitigazione del traffico (rate limiting).
- Valutare un piano di continuità operativa (ridondanza infrastrutturale).

Gestione di un'infezione malware sulla Web App

Descrizione del rischio:

In caso di compromissione del server web, un malware potrebbe propagarsi verso la rete interna, con conseguenze potenzialmente gravi per la sicurezza dei dati e la continuità operativa.

Obiettivo della risposta:

La priorità è contenere la propagazione del malware verso la rete interna. Non è richiesto, in questa fase, il ripristino immediato dell'accesso da parte dell'attaccante alla macchina compromessa.

Raccomandazione:

Isolare il server infetto interrompendo la comunicazione tra DMZ e rete interna. In questo modo si riduce il rischio di lateral movement (movimenti laterali dell'attaccante all'interno della rete).

Soluzione integrata

La soluzione finale proposta prevede l'integrazione delle misure preventive (WAF, SIEM/SOAR) con la strategia di contenimento in caso di compromissione (isolamento della DMZ).

Questa configurazione garantisce:

- maggiore protezione contro attacchi applicativi;
- monitoraggio continuo e capacità di risposta;
- contenimento del rischio in caso di compromissione, evitando l'esposizione della rete interna.

Conclusioni

L'analisi condotta evidenzia che l'infrastruttura attuale presenta un livello di rischio significativo, principalmente per la possibilità di accesso dalla DMZ verso la rete interna e per l'assenza di protezioni specifiche contro attacchi applicativi e DDoS.

Le misure proposte da NemiSec (implementazione di WAF, monitoraggio centralizzato, protezioni anti-DDoS e strategia di isolamento in caso di compromissione) sono volte a ridurre in modo concreto e misurabile il rischio operativo e l'impatto economico derivante da possibili incidenti.

NemiSec rimane a disposizione per supportare **Banana Inc.** nella fase di implementazione delle misure e nella definizione di un piano di sicurezza continuativo.